

Incident Report: "RedSun" Adversary Emulation Against DC01

Field	Value
Report ID	IR-2026-REDSUN-001
Classification	Internal / Purple Team Lab Exercise
Incident type	Simulated domain intrusion (recon to privilege escalation)
Primary target	DC01.lab.local (192.168.86.100)
Source host	attacker-01, Kali Linux (192.168.86.149)
Domain	lab.local
Incident date	April 18, 2026
Endpoint AV validation	April 27, 2026
Analyst / Author	Kasra Saiidi
Overall severity	High (contained; Critical if unmitigated)
Status	Contained

1. Executive Summary

On April 18, 2026, a simulated adversary operating from attacker-01 (Kali Linux, 192.168.86.149) executed a full intrusion chain against DC01.lab.local, the Windows Server 2025 domain controller for the lab.local Active Directory domain. The chain moved from unauthenticated network reconnaissance, through valid-username enumeration and a password attack against the domain account `lab\attacker`, to authenticated remote access over WinRM, on-host delivery and compilation of a custom local privilege escalation binary ("RedSun.exe"), and a privilege escalation attempt.

The intrusion was detected on two independent layers. Microsoft Defender detected and quarantined the RedSun payload at the endpoint (event IDs 1116 and 1117), and six custom

Elastic SIEM detection rules mapped to MITRE ATT&CK provided coverage across the credential access, lateral movement, privilege escalation, and persistence phases. The compromised account remained at low privilege, and the privilege escalation payload was quarantined before SYSTEM-level execution was confirmed, so no privilege escalation or domain compromise was achieved in this run.

The single most important finding: initial access succeeded only because of a weak, guessable password (**Password123!**) on a domain account. Everything downstream in the chain depended on that first failure.

2. Affected and Monitored Assets

Asset	Role	IP / Identifier	Notes
DC01.lab.local	Domain controller (Windows Server 2025, Build 26100)	192.168.86.100	Primary target; AD, DNS, Kerberos, LDAP, SMB, RDP, WinRM exposed
attacker-01	Adversary host (Kali Linux)	192.168.86.149	Origin of all attacker activity
DESKTOP-UNMEE1M	Monitored Windows endpoint (Defender + Elastic Agent)	(lab endpoint)	Source of the malware detection and quarantine telemetry
siem-01	Elastic SIEM / Kibana / Fleet	192.168.86.148	Detection and alerting platform

3. Attack Timeline

All attacker timestamps are from attacker-01 (April 18, 2026). Endpoint anti-malware validation was performed in a later session (April 27, 2026); timestamps are presented as recorded.

Time (approx)	Phase	Action	Evidence	MITRE ATT&CK
01:13	Reconnaissance	<code>nmap -sV -sC 192.168.86.100</code> ; full service and version scan of the DC	Nmap output identifying DC01.lab.local, Windows Server 2025, open AD services	T1046 Network Service Discovery
01:27:33	Discovery	<code>kerbrute userenum --dc 192.168.86.100 -d lab.local</code> ; enumerated valid domain usernames via Kerberos pre-auth	Kerbrute confirmed <code>administrator@lab.local</code> and <code>attacker@lab.local</code> as valid	T1087.002 Account Discovery: Domain Account
~01:30	Credential Access	<code>crackmapexec smb 192.168.86.100 -u attacker -p /tmp/passwords.txt</code> ; password attack against the <code>attacker</code> account	CME returned <code>lab.local\attacker:Password123!</code>	T1110.001 Brute Force: Password Guessing
~01:35	Initial Access	<code>evil-winrm -i 192.168.86.100 -u attacker -p Password123!</code> ; established authenticated PowerShell session	Evil-WinRM v3.9 shell as <code>lab\attacker</code>	T1078.002 Valid Accounts; T1021.006 Remote Services: WinRM

Time (approx)	Phase	Action	Evidence	MITRE ATT&CK
01:48	Execution	Delivered RedSun.cpp (27,276 bytes) to C:\Users\attacker\	dir output showing the source file on target	T1105 Ingress Tool Transfer
~13:08	Defense Evasion	Compiled RedSun.exe (134,656 bytes) on the target using local Visual Studio cl.exe	Build output and dir confirming C:\Users\attacker\RedSun.exe	T1027.004 Compile After Delivery
(session)	Privilege Escalation	Executed RedSun (LPE tooling abusing MsMpEng.exe to write into System32); privilege state remained low (whoami /priv shows key privileges Disabled)	whoami /priv output; no elevation confirmed	T1068 Exploitation for Privilege Escalation
Apr 27, 00:44:34	Detection (endpoint)	Microsoft Defender detected the RedSun payload	event.code 1116, event.action malware-detected, host DESKTOP-UNMEE1M	Detection / DS0009
Apr 27, 00:45:46	Containment (endpoint)	Microsoft Defender quarantined the RedSun payload	event.code 1117, event.action malware-quarantined, status verified	Containment

4. Attack Chain Narrative

4.1 Reconnaissance

The adversary began with an unauthenticated `nmap -sV -sC` scan of 192.168.86.100. The scan positively identified the host as a domain controller (DC01.lab.local, lab.local domain, Windows Server 2025 Build 26100) by fingerprinting the classic AD service set: DNS (53), Kerberos (88), RPC (135), NetBIOS (139), LDAP (389), SMB (445), kpasswd (464), Global Catalog LDAP (3268), RDP (3389), and WinRM/HTTPAPI (5985). The scan also surfaced a clock skew of roughly two hours between the attacker host and the DC, which is operationally relevant for timeline correlation in the SIEM.

```
(root@Attacker-01) ~/home/kali/RedSun
# nmap -sV -sC 192.168.86.100
Starting Nmap 7.92 ( https://nmap.org ) at 2026-04-18 01:13 -0500
Nmap scan report for 192.168.86.100
Host is up (0.0011s latency).
Not shown: 987 filtered tcp ports (no-response)
PORT      STATE SERVICE      VERSION
53/tcp    open  domain       Simple DNS Plus
88/tcp    open  kerberos-sec Microsoft Windows Kerberos (server time: 2026-04-18 08:13:27Z)
135/tcp   open  msrpc        Microsoft Windows RPC
139/tcp   open  netbios-ssn  Microsoft Windows netbios-ssn
389/tcp   open  ldap         Microsoft Windows Active Directory LDAP (Domain: lab.local, Site: Default-First-Site-Name)
445/tcp   open  microsoft-ds?
464/tcp   open  kpasswd5?
593/tcp   open  ncacn_http   Microsoft Windows RPC over HTTP 1.0
636/tcp   open  tcpwrapped
3268/tcp  open  ldap         Microsoft Windows Active Directory LDAP (Domain: lab.local, Site: Default-First-Site-Name)
3389/tcp  open  tcpwrapped
3389/tcp  open  ms-wbt-server
|_ssl-date: TLS randomness does not represent time
|_rdp-nla-info:
|_Target_Name: LAB
|_NetBIOS_Domain_Name: LAB
|_NetBIOS_Computer_Name: DC01
|_DNS_Domain_Name: lab.local
|_DNS_Computer_Name: DC01.lab.local
|_DNS_Tree_Name: lab.local
|_Product_Version: 10.0.26100
|_System_Time: 2026-04-18T08:13:32+00:00
|_ssl-cert: Subject: commonName=DC01.lab.local
|_Not valid before: 2026-03-31T02:58:57
|_Not valid after: 2026-09-30T02:58:57
5985/tcp  open  http         Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
|_http-server-header: Microsoft-HTTPAPI/2.0
|_http-title: Not Found
1 service unrecognized despite returning data. If you know the service/version, please submit the following fingerprint at https://nmap.org/cgi-bin/submit.cgi?new-service :
SF-Port3389-TCP:V=7.98I=74D=4/18YTime=69E3218DNP=x86_64-pc-linux-gnuK(Te
SF:rminalServerCookie,13,"x03\0\0\x13\x0e\x00\0\0\x124\0\x02\0\x08\0\x02\
SF:0\0\0?);
MAC Address: BC:24:11:40:9A:D8 (Proxmox Server Solutions GmbH)
Service Info: Host: DC01; OS: Windows; CPE: cpe:/o:microsoft:windows

Host script results:
|_smb2-security-mode:
|_ 3.1.1:
|_   Message signing enabled and required
|_nbstat: NetBIOS name: DC01, NetBIOS user: <unknown>, NetBIOS MAC: bc:24:11:40:9a:d8 (Proxmox Server Solutions GmbH)
|_smb2-time:
|_  date: 2026-04-18T08:13:33
|_  start_date: N/A
|_clock-skew: mean: 1h59m58s, deviation: 0s, median: 1h59m57s

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 58.81 seconds
```

4.2 Username Enumeration

Using Kerbrute against the KDC, the adversary abused Kerberos pre-authentication responses to distinguish valid from invalid usernames without generating standard failed-logon noise. Two valid accounts were confirmed: `administrator` and `attacker`. This narrowed the credential attack surface before a single password was attempted.


```

(root@Attacker-01)-[/home/kali/RedSun]
# evil-winrm -i 192.168.86.100 -u attacker -p Password123!
Evil-WinRM shell v3.9

Warning: Remote path completions is disabled due to ruby limitation: undefined method `quoting_detection_proc' for module Reline
Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm#Remote-path-completion
Info: Establishing connection to remote endpoint
*Evil-WinRM* PS C:\Users\attacker\Documents> whoami
lab\attacker
*Evil-WinRM* PS C:\Users\attacker\Documents> whoami /priv

PRIVILEGES INFORMATION
=====
| Privilege Name | Description | State |
|-----|-----|-----|
| SeMachineAccountPrivilege | Add workstations to domain | Enabled |
| SeChangeNotifyPrivilege | Bypass traverse checking | Enabled |
| SeIncreaseWorkingSetPrivilege | Increase a process working set | Enabled |

```

4.5 Tooling and On-Host Compilation

The adversary transferred `RedSun.cpp` to the target and then compiled it on the host with the locally present Visual Studio toolchain (`cl.exe`), producing `RedSun.exe`. Compiling after delivery is a defense-evasion technique: the malicious binary never crosses the network as a finished executable, reducing the chance of signature-based detection in transit. The presence of a full build toolchain on a domain controller is itself a serious hardening gap.

```

/out:C:\Users\attacker\RedSun.exe
cfgmgr32.lib
cldapi.lib
advapi32.lib
user32.lib
ole32.lib
RedSun.obj

C:\Program Files\Microsoft Visual Studio\18\Community>dir C:\Users\attacker\RedSun.exe
Volume in drive C has no label.
Volume Serial Number is BCF7-5398

Directory of C:\Users\attacker

04/18/2026  01:08 PM                134,656 RedSun.exe
               1 File(s)                134,656 bytes
               0 Dir(s)  35,828,260,864 bytes free

```

4.6 Privilege Escalation Attempt

RedSun is local privilege escalation tooling. The associated detection ("RedSun LPE: Defender Writing to System32") targets the Defender engine process `MsMpEng.exe` writing into `System32`, indicating the technique abuses the anti-malware service to gain a write primitive in a protected directory. The attempt did not result in confirmed elevation: `whoami /priv` continued to show key privileges (for example `SeMachineAccountPrivilege`,

SeIncreaseWorkingSetPrivilege) in a Disabled state, and Defender subsequently detected and quarantined the payload.

```
PS C:\Users\attacker> whoami /priv

PRIVILEGES INFORMATION
=====

Privilege Name      Description                State
=====
SeMachineAccountPrivilege  Add workstations to domain  Disabled
SeChangeNotifyPrivilege   Bypass traverse checking    Enabled
SeIncreaseWorkingSetPrivilege  Increase a process working set Disabled
PS C:\Users\attacker>
```

4.7 Detection and Containment

Microsoft Defender independently detected (event 1116) and quarantined (event 1117) the RedSun payload on the monitored endpoint, with quarantine status reported as verified. Combined with the SIEM rule coverage below, this gave two independent detection points for the same tooling.

```
✓ Apr 27, 2026 @ 00:44:34.607 agent.name DESKTOP-UNMEEU event.code 1116 @timestamp Apr 27, 2026 @ 00:44:34.607 agent.ephemeral_id f966bbe7-488a-462d-9cf9-68c4ed1e1db0 agent.id ff01de13-6442-47eb-9762-37c6e663b74b agent.type filebeat
t agent.version 8.19.14 data_stream.dataset windows.windows_defender data_stream.namespace default data_stream.type logs ecs.version 8.17.0 elastic_agent.id ff01de13-6442-47eb-9762-37c6e663b74b
b elastic_agent.snapshot false elastic_agent.version 8.19.14 event.action malware-detected event.agent_id_status verified event.category malware event.created Apr 27, 2026 @ 16:43:25.367 event.dataset_

✓ Apr 27, 2026 @ 00:44:34.602 agent.name DESKTOP-UNMEEU event.code 1116 @timestamp Apr 27, 2026 @ 00:44:34.602 agent.ephemeral_id f966bbe7-488a-462d-9cf9-68c4ed1e1db0 agent.id ff01de13-6442-47eb-9762-37c6e663b74b agent.type filebeat
t agent.version 8.19.14 data_stream.dataset windows.windows_defender data_stream.namespace default data_stream.type logs ecs.version 8.17.0 elastic_agent.id ff01de13-6442-47eb-9762-37c6e663b74b
b elastic_agent.snapshot false elastic_agent.version 8.19.14 event.action malware-detected event.agent_id_status verified event.category malware event.created Apr 27, 2026 @ 16:43:25.356 event.dataset_

✓ Apr 27, 2026 @ 00:45:46.981 agent.name DESKTOP-UNMEEU event.code 1117 @timestamp Apr 27, 2026 @ 00:45:46.981 agent.ephemeral_id f966bbe7-488a-462d-9cf9-68c4ed1e1db0 agent.id ff01de13-6442-47eb-9762-37c6e663b74b agent.type filebeat
t agent.version 8.19.14 data_stream.dataset windows.windows_defender data_stream.namespace default data_stream.type logs ecs.version 8.17.0 elastic_agent.id ff01de13-6442-47eb-9762-37c6e663b74b
b elastic_agent.snapshot false elastic_agent.version 8.19.14 event.action malware-quarantined event.agent_id_status verified event.category malware event.created Apr 27, 2026 @ 16:43:25.36_

✓ Apr 27, 2026 @ 00:45:46.952 agent.name DESKTOP-UNMEEU event.code 1117 @timestamp Apr 27, 2026 @ 00:45:46.952 agent.ephemeral_id f966bbe7-488a-462d-9cf9-68c4ed1e1db0 agent.id ff01de13-6442-47eb-9762-37c6e663b74b agent.type filebeat
t agent.version 8.19.14 data_stream.dataset windows.windows_defender data_stream.namespace default data_stream.type logs ecs.version 8.17.0 elastic_agent.id ff01de13-6442-47eb-9762-37c6e663b74b
b elastic_agent.snapshot false elastic_agent.version 8.19.14 event.action malware-quarantined event.agent_id_status verified event.category malware event.created Apr 27, 2026 @ 16:43:25.36_
```

5. Detection Coverage (Elastic SIEM)

Six custom detection rules were authored for this environment and mapped to MITRE ATT&CK. The table distinguishes rules that fired on activity observed in this run from rules that provide standing coverage for techniques not directly exercised here.

Rule	Severity / Risk	Logic (summary)	MITRE	Status this run
Brute Force: Multiple Failed	Medium / 60	Threshold: event.code 4625 aggregated by	T1110	Corresponds to observed credential attack

Rule	Severity / Risk	Logic (summary)	MITRE	Status this run
Authentication Attempts		TargetUserName >= 5 in 5 min		
RedSun LPE: Defender Writing to System32	Critical / 90	process.name : MsMpEng.exe AND file.path: *System32* AND event.action : file_write	T1068	Corresponds to observed LPE tooling
Privilege Escalation: Special Privileges Assigned to New Logon	High / 75	event.code 4672, excluding SYSTEM / LOCAL SERVICE / NETWORK SERVICE	T1068	Standing coverage
Credential Dumping: LSASS Access	Critical / 95	event.code: 4656 AND winlog.event_data.Object Name: *lsass*	T1003.001	Standing coverage
Pass-the-Hash: NTLM Lateral Movement	Critical / 90	event.code 4624, LogonType 3, NTLM, KeyLength 0	T1550.002	Standing coverage
Persistence: New Local User Account Created	Medium / 50	event.code 4720	T1136.001	Standing coverage

Endpoint detection layer: Microsoft Defender for Endpoint, `windows.windows_defender` dataset via Elastic Agent, events 1116 (detected) and 1117 (quarantined).

5.1 Rule Definitions

RedSun LPE - Defender Writing to System32

Created by elastic on Apr 17, 2028 @ 19:40:42.600

Updated by elastic on Apr 17, 2028 @ 19:40:42.600

Last response:

Notify when alerts generated

About

Description

Rule that detects any file rewriting that could lead to privilege escalation.

Author

Kara Seld

Severity

Critical

Risk score

90

MITRE ATT&CK™

Privilege Escalation (TA0004)

Exploitation for Privilege Escalation (T1068)

Max alerts per run

100

Definition

Index patterns

logs-* winlogbeat-*

Custom query

process.name: "MsMpEng.exe" and file.path: "*System32*" and event.action: "file_write"

Custom query language

KQL

Rule type

Query

Timeline template

None

Schedule

Runs every

5m

Additional look-back time

1h

elastic

Find apps, content, and more.

Security Rules Detection rules (86) Alerts

ML job settings Add integrations Data view (Alerts)

Security

Filter your data using KQL syntax

Last 1 year Refresh

Dashboards Rules Alerts Attack discovery Findings Cases Timelines Intelligence Explore

Credential Dumping: LSASS Access

Created by elastic on Apr 18, 2028 @ 00:43:55.493

Updated by elastic on Apr 18, 2028 @ 00:43:55.493

Last response:

Notify when alert is generated

About

Description

Detects attempts to access the LSASS process memory, which is commonly used by tools like Mimikatz to extract plaintext passwords and NTLM hashes from memory. This technique is mapped to MITRE ATT&CK T1003.001 and is a strong indicator of credential theft activity.

Author

Kara Seld

Severity

Critical

Risk score

95

MITRE ATT&CK™

Credential Access (TA0008)

OS Credential Dumping (T1003)

LSASS Memory (T1055.001)

Max alerts per run

100

Definition

Index patterns

logs-* winlogbeat-*

Custom query

event.code:"4656" and winlog.event_data.ObjectName:"lsass"

Custom query language

KQL

Rule type

Query

Timeline template

None

Schedule

Runs every

5m

Additional look-back time

1h

Pass-the-Hash - NTLM Lateral Movement

Created by elastic on Apr 18, 2028 @ 00:49:12.716

Updated by elastic on Apr 18, 2028 @ 00:49:12.716

Last response:

Notify when alerts generated

About

Description

Detects NTLM authentication events where a user authenticates to a remote system without a plaintext password, indicative of Pass-the-Hash activity. Attackers use stolen NTLM hashes to move laterally across the network without needing the actual password.

Severity

Critical

Risk score

90

MITRE ATT&CK™

Lateral Movement (TA0008)

Use Alternative Authentication Material (T1550)

Pass the Hash (T1550.002)

Max alerts per run

100

Definition

Index patterns

logs-* winlogbeat-*

Custom query

event.code:"4624" and winlog.event_data.LogonType:"5" and winlog.event_data.AuthenticationPackage:"NTLM" and winlog.event_data.KeyLength:"16"

Custom query language

KQL

Rule type

Query

Timeline template

None

Schedule

Runs every

5m

Additional look-back time

1h

Brute Force - Multiple Failed Authentication Attempts

Created by: elastic on Apr 18, 2020 @ 00:00:04.911 Updated by: elastic on Apr 18, 2020 @ 00:00:00.000

Last response: ● succeeded at Apr 18, 2020 @ 00:55:57.028 🔗 🔔 🔔 Notify when alerts generated



Enable

[Edit rule settings](#)



About

Description

Detects multiple consecutive failed authentication attempts against a single account or system, which may indicate a password spray or brute force attack. Threshold set to trigger after 5 failed attempts within a 5 minute window.

Author

Kaara Saltil

Severity

Medium

Risk score

60

MITRE ATT&CK™

Credential Access (TA0006) 🔗

L. Brute Force (T1110)

Max alerts per run

100

Definition

Index patterns

logs-* | winlogbeat-*

Custom query

event.code:"4625"

Custom query language

KQL

Rule type

Threshold

Timeline template

None

Threshold

Results aggregated by
winlog.event_data.TargetUserName >> 5

Schedule

Runs every

5m

Additional look-back time

1h

Privilege Escalation - Special Privileges Assigned to New Logon

Created by: elastic on Apr 18, 2020 @ 01:02:23.185 Updated by: elastic on Apr 18, 2020 @ 01:02:23.185

Last response: ● 🔗 🔔 🔔 Notify when alerts generated



Enable

[Edit rule settings](#)



About

Description

Detects Event ID 4672, which is generated when special privileges are assigned to a new logon session. This can indicate successful privilege escalation, particularly when observed following suspicious low-privilege user activity.

Author

Kaara Saltil

Severity

High

Risk score

75

MITRE ATT&CK™

Privilege Escalation (TA0004) 🔗

L. Exploitation for Privilege Escalation (T1068)

Max alerts per run

100

Definition

Index patterns

logs-* | winlogbeat-*

Custom query

event.code:"4672" and not
winlog.event_data.SubjectUserName: ("SYSTEM" or
"LOCAL SERVICE" or "NETWORK SERVICE")

Custom query language

KQL

Rule type

Query

Timeline template

None

Schedule

Runs every

5m

Additional look-back time

1h

persistence - New Local User Account Created

Created by: elastic on Apr 18, 2020 @ 01:06:26.263 Updated by: elastic on Apr 18, 2020 @ 01:06:26.263

Last response: ● 🔗 🔔 🔔 Notify when alerts generated



Enable

[Edit rule settings](#)



About

Description

Detects the creation of new local user accounts via Event ID 4720. Attackers commonly create backdoor accounts after gaining elevated access to maintain persistence on compromised systems.

Author

Kaara Saltil

Severity

Medium

Risk score

50

MITRE ATT&CK™

Persistence (TA0003) 🔗

L. Create Account (T1066)

L. Local Account (T1136.001)

Max alerts per run

100

Definition

Index patterns

logs-* | winlogbeat-*

Custom query

Event.code:"4720"

Custom query language

KQL

Rule type

Query

Timeline template

None

Schedule

Runs every

5m

Additional look-back time

1h

6. Indicators of Compromise (IOCs)

Network

- Source IP: 192.168.86.149 (attacker-01)
- Target IP: 192.168.86.100 (DC01)

Accounts

- lab\attacker (compromised)
- Password observed in use: Password123! (weak, should be treated as burned)

Files

- C:\Users\attacker\RedSun.cpp (27,276 bytes)
- C:\Users\attacker\RedSun.exe (134,656 bytes)

Tooling observed

- kerbrute v1.0.3
- nmap 7.98
- CrackMapExec (SMB)
- Evil-WinRM v3.9
- Visual Studio cl.exe used for on-host compilation (living off the land)

Windows event signatures

- 4625 (failed logon burst)
 - 4624 LogonType 3 (remote authentication)
 - 4672 (special privileges assigned)
 - Defender 1116 / 1117 on DESKTOP-UNMEE1M
 - MsMpEng.exe writing to System32
-

7. Impact Assessment

Dimension	Assessment
Confidentiality	Low realized. Foothold obtained on the DC, but no confirmed data access or credential dumping in this run.
Integrity	Low realized. Privilege escalation attempted but not confirmed; payload quarantined.
Availability	None observed.
Blast radius (unmitigated)	Critical. A successful LPE on a domain controller leads directly to domain-wide compromise. The gap between "contained" and "catastrophic" here was Defender quarantine and a failed elevation, not a robust control.

8. Recommendations and Remediation

Priority order:

1. **Eliminate weak credentials.** Password123! on a domain account is the root cause. Enforce a strong password policy, screen against breached-password lists, and rotate the attacker account credential. This single control breaks the entire chain at step 3.
 2. **Require MFA on remote administrative access.** WinRM (5985) and RDP (3389) into a domain controller should not be reachable with a password alone.
 3. **Restrict WinRM and RDP exposure.** Limit which hosts and accounts can reach these services on the DC; segment the DC away from general workstation subnets.
 4. **Remove build tooling from servers.** A Visual Studio toolchain on a domain controller enabled compile-after-delivery. Domain controllers should not carry compilers or developer tooling.
 5. **Harden Microsoft Defender.** Enable tamper protection and Attack Surface Reduction rules; the LPE technique specifically targeted the Defender engine process.
 6. **Adopt tiered administration and LAPS.** Separate Tier 0 (DC) credentials from workstation credentials to contain any single account compromise.
-

9. Detection Engineering Notes

Observations for improving coverage, written from the blue-team side of this exercise:

- **Reconnaissance gap.** The Nmap scan and Kerbrute enumeration were not caught by a dedicated rule. Add detection for Kerberos username enumeration (4768/4771 with failure code 0x6 for unknown principals, plus high-volume ticket requests from a single source) so the earliest phase of the chain generates an alert rather than only the later credential attack.
 - **On-host compilation.** Consider a rule for developer toolchain execution on servers (for example `cl.exe`, `csc.exe`, `link.exe` process starts on Tier 0 assets), which would have flagged the compile-after-delivery step independently of the payload signature.
 - **Clock skew and correlation.** Nmap reported roughly a two-hour skew between the attacker host and DC01. Time skew on the domain controller distorts event ordering in Kibana timelines and can split a single attack across apparent windows. Verify NTP sync and timezone on the DC before relying on cross-source correlation.
 - **Layered validation held up.** The same tooling was caught by both a custom SIEM rule (process/file-write logic) and endpoint AV (signature). Independent detection layers for one technique is the outcome to aim for.
-

10. MITRE ATT&CK Summary

Tactic	Technique	ID
Discovery	Network Service Discovery	T1046
Discovery	Account Discovery: Domain Account	T1087.002
Credential Access	Brute Force: Password Guessing	T1110.001
Initial Access	Valid Accounts: Domain Accounts	T1078.002
Lateral Movement	Remote Services: Windows Remote Management	T1021.006
Command and Control	Ingress Tool Transfer	T1105
Defense Evasion	Compile After Delivery	T1027.004

Tactic	Technique	ID
Privilege Escalation	Exploitation for Privilege Escalation	T1068

Prepared by Kasra Saiidi. Environment: self-hosted Elastic SIEM lab (lab.local). This report documents a controlled adversary emulation exercise conducted for detection engineering and portfolio purposes.